Ref. Ares(2026)8344648 - 01/09/2026

APPENDIX 3

EASA Security Baseline for External Connections – Rules for Contractors and service providers (including Individual Service Provider Security Commitment)

Contents

1 BACKGROUND 2
2 SCOPE 3
2.1 PROVISION OF SERVICES 3
2.2 INFORMATION HANDLING 3
3 APPROACH 3
4 CONTRACTING AUTHORITY RESPONSIBILITIES 4
4.1 CONTRACT PREPARATION 4
4.2 COMMENCEMENT OF SERVICES 5
4.3 TERMINATION 5
5 REFERENCES 6
6 RULES FOR CONTRACTORS 6
6.1 BASELINE RULES FOR ALL SCENARIOS 7
6.1.1 General rules 7
6.1.2 Access Control 9
6.1.3 Awareness and Training 9
6.1.4 Security Assessment and Authorisation 9
6.1.5 Identification and Authentication 10
6.1.6 Incident Response 10
6.1.7 Media Protection 10
6.1.8 Personnel Security 11
7 INDIVIDUAL SERVICE PROVIDER SECURITY COMMITMENT 11

1 BACKGROUND

This document contains the baseline security measures for contractors ([1]) and service providers in the categories PPI, PPW, PXE and PXI when performing remote service delivery.

The categories are defined as follows:

- **P**rovider **P**remises **W**orkstation (**PPW**): Service provider with access to premises and a workstation (EASA office space and individual EASA IT equipment).
- **P**rovider **P**remises **I**T access (**PPI**): Service provider with regular IT access rights and regular access to buildings but that do not occupy a workstation.
- **P**rovider e**X**ternal IT **E**quipment (**PXE**): Service Provider hosted outside EASA premises with a "replicated" environment, EASA IT equipment and security measures.
- **P**rovider e**X**ternal **I**T access (**PXI**): Service provider with access to certain individually defined IT tools and systems to work remotely that do not need regular access to EASA premises, they do not have EASA IT equipment.

Additionally, there are two categories (PP – Provider Premises – and Not encoded) which do not have access to EASA information systems and are not covered by this baseline.

The rules in this document specify the minimal security measures that contractors are required to put in place to mitigate risks to the security of EASA information during the fulfilment of the contracted services ([2]). They focus mainly on the confidentiality and integrity of EASA equipment and information (measures to ensure high availability may also be relevant when required in the service level agreement but are out of scope of this document). It should be noted that any security obligations on the contractors and service providers must be included in the relevant contracts, including in particular the compliance and verification requirements, in line with this security baseline.

The permitted modes for service delivery should be stipulated in the service contract, in particular whether remote service delivery is permitted (or even required), and under which conditions. Depending on the category (PPI, PPW, PXE, or PXI), the service provider may or may not be assigned IT equipment by EASA. When the contractor undertakes to follow these security rules in the contract, access for PPI, PPW and PXE service providers is permitted without an additional Interconnection Security Agreement (ISA). An ISA is still required for services provided with PXI service providers using custom interconnections. The ISA shall be generated by the contractor and approved by EASA (see section 6.2).

EASA may verify the compliance with this baseline at any time, either with its own staff or through the use of a third party (the cost is borne by the contracting authority unless stated otherwise in the contract).

([1]) In EASA terminology, the **contractor** is the company having a contract with the EASA, and a **service provider** is an individual consultant that works for the contractor.

([2]) The relevant risks and high-level security requirements are laid out in the Standard on external network connections Standard C(2021) 8428 on External network connections (see https://ec.europa.eu/info/files/security-standards-information-systems_en)..

2 SCOPE

2.1 PROVISION OF SERVICES

This security baseline covers all scenarios whereby service providers may perform remote service delivery, accessing EASA information in communication and information systems (CISs) on the EASA's internal network or in outsourced environments. Some of these categories of service providers use EASA IT equipment (normally a laptop) and connect to the EASA's internal network via the remote access service for EASA staff (PPW and PXE); the other categories (PPI and PXI) are not assigned a dedicated EASA end device but have IT access and may use equipment not issued by EASA to access EASA IT services remotely.
When performing remote service delivery, service providers may work in contractor premises or in home offices, where permitted by the contract.
Any remote service delivery site for a service provider must be located in an EU Member State (service providers may also exceptionally participate in missions outside the EU with authorisation from the contracting authority). A home office may be his/her own home or a similar location such as the residence of a relative or partner where the relevant security measures can be applied. Remote service delivery is not permitted from public spaces (e.g. hotel lobbies, restaurants, airports, train stations, social clubs…).
Where the controls refer to contractor or service provider equipment, this applies to the network equipment (particularly the network switches, proxies, (wi-fi) routers and boundary protection devices) that is used for the connections to the EASA's remote access services or EASA CISs.

2.2 INFORMATION HANDLING

This baseline covers the handling of EASA information in transit and at rest on IT equipment or infrastructure used by service providers (including EASA or contractor laptops ([3]), the EASA networks and CISs to which they connect, and any removable media supplied by the EASA).
The handling of EASA information in EASA CISs that are outsourced is out of scope.
This baseline does not cover the handling of information in other repositories or systems (including removable media not issued by EASA, contractors' file stores or cloud systems that are not owned by EASA).
EU classified information (EUCI) is out of scope of this baseline. Any access to EUCI must follow the specific rules in place at EASA.

3 APPROACH

The general and specific rules in section 6 of this document must be followed by the contractor and its service providers as appropriate. Section 6 is split into two parts: the first part contains rules that are mandatory in all situations, and the second part contains additional scenario-specific rules for custom interconnections.
In addition, the contractor must ensure that all service providers sign the individual service provider security commitment in section 7 below, indicating the specific responsibilities of the individual service providers.

([3]) NB in this context, contractor laptops may only be used to access EASA CISs and may not be used to store EASA information.

The contracting authority will provide service descriptions and a set of facilities (e.g. IT equipment, access passes and IT access) as described in section 4 below to enable the contractor to fulfil its security responsibilities.
The rules are partly based on the NIST Special Publication (SP) 800-53 (revision 5), Security and Privacy Controls for Information Systems and Organizations and the EASA's internal security standards, taking account of controls that are relevant for remote service provision. The NIST publication was selected since it is publicly available, relatively detailed and considered as an industry standard.
Additional material has been included from the "CIS Critical Security Controls", published by the Centre for Internet Security (cisecurity.org), and from the EASA's internal security policies.
EASA's internal security policies and standards, unless stated otherwise are identical or based on the Commission's general security rules listed in the references.
Contractors must implement the required controls and document their implementation or deviations, which may be requested or audited by the contracting authority at any time.

4 CONTRACTING AUTHORITY RESPONSIBILITIES

The contracting authority has a number of responsibilities to support contractors and service providers in the secure provision of external services. The key responsibilities relating to this document occur during contract preparation, at the start of a service provider's work (commencement of services) and at the end of a service provider's work (termination).

4.1 CONTRACT PREPARATION

During contract preparation:

- The contracting authority will describe the services to be provided by the contractor in the framework contract and/or in the service contract defining the scope of remote service delivery activities, personnel and sites. The contract must include the obligations that the contractor has to impose on the service providers in the areas of information confidentiality and handling.
- The contracting authority will determine the appropriate category of service provider depending on factors such as the nature of the tasks and any security considerations.
- System owners must create service provider profiles (developer, tester, system administrator, project manager etc.) specifying the accesses required for the service providers to deliver services in line with the business requirements and the available network service offerings. The profiles include the basic network access and any additional access to EASA CISs that is needed.
- The requesting service in the EASA will inform the contractor which tasks are considered to be highly sensitive, and therefore what sort of security verification is required (see controls PS-2 and PS-3 in section 6). The options are:
  i) Standard;
  ii) Highly sensitive (tasks requiring a security clearance).
- EASA system owners must ensure that all EASA CIS and services that are accessed by service providers must take account of the risks and security measures relating to their use by external personnel. This should be documented in the IT security plans of the systems accessed.

- EASA IT equipment must only be delivered (where applicable) to new service providers in person after the verification of the service provider's identity by the service cards office. The standard IT delivery procedures apply.

4.2 COMMENCEMENT OF SERVICES

Before service providers start to work under the contract:

- the service provider must sign the individual service provider security commitment and send it to the contracting authority;
- where relevant, the contracting authority will ensure that the form PO.FACIL.00044 is completed and signed yearly by the contractor to enable the issuing of the pass granting access to EASA premises (the type of pass issued may depend on the category of the service provider);
- where relevant, the contracting authority will request the provision of the EASA IT equipment from the DTT (normally a laptop for PPW and PXE service providers);
- the contracting authority will return the signed form FO.FACIL.00044 to the Security Office to ensure that the appropriate security screening is performed for the service provider as a part of the registration process.

At the start of the contract:

- PPI, PPW and PXE service providers must make an appointment at the Security Office for validation of their identity and issuance of an access badge;
- after this validation and where relevant, the service provider will collect the EASA IT equipment at the EASA's premises in Cologne; and
- EASA may provide a certificate for security purposes when required (e.g. for email services or remote access authentication).

During the first three months of work for each service provider ([4]):

- The CISO will provide an introductory briefing on information security at EASA.

At the request of the contracting authority, system owners will grant access to the EASA communication and information systems (CIS) as required for the contracted services with appropriate authorisations, in line with security principles (particularly least privilege).

The contracting authority must ensure that service providers are aware of the level of sensitivity of any information handled, and the corresponding handling instructions.

If service providers need to use removable media to store or handle EASA information, these must be supplied by the contracting authority.

If PXI service providers who do not possess an access badge need to come to EASA's premises during the provision of services, they may obtain an access pass from the guards at building access points upon presentation of a valid national identity card or passport.

4.3 TERMINATION

Upon the termination of work of an individual service provider:

- The contracting authority must ensure that all EASA assets (EASA information, laptop, hardware tokens, IT equipment, access badges etc.) are returned to the EASA;

([4]) Each service provider must follow the briefing once when they start to work for EASA, or for existing service providers upon the adoption of this document. Service providers are not required to follow the briefing again for subsequent contracts.

- The DTT must update the relevant equipment inventory records;
- the contracting authority must notify the system owners of CISs to which the service provider has access; and
- system owners will immediately terminate all access granted to the service provider for the EASA's networks and CISs.

These points must also be addressed as relevant when a service provider finishes a contract and begins a new contract with different tasks or in a different part of EASA.

5 REFERENCES

Description	Reference
The Commission's general security rules	https://ec.europa.eu/info/files/security-standards-information-systems_en
NIST SP 800-53 rev5	https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
CIS Critical Security Controls	https://www.cisecurity.org/controls/ ([5])

6 RULES FOR CONTRACTORS

These rules are split into two parts:

- The first part (section 6.1) contains rules that are applicable for all categories of service providers (PPI, PPW, PXE, PXI) and in all scenarios.
- The second part (section 6.2) contains additional rules that apply when the target EASA CIS (system, service or infrastructure) is not accessible by default via external gateways and requires a custom interconnection (covered by an ISA). Furthermore, the rules in section 6.2 apply on remote service delivery locations (on contractor premises) when equipment and devices that are owned by the contractor are used to access EASA CISs for the provision of services to the contracting authority.

The baseline controls are organised within the framework laid out in NIST SP 800-53. These controls are designed to be consistent with the security stance of the EASA's general security rules, while using publicly available standards for ease of reference.
Each control includes its NIST ID and the title of the control area, and the specific security measures that are required by the EASA. The controls in the security baseline are based on the NIST controls that are relevant for the provision of services to the EASA, with input from the CIS Critical Security Controls where necessary. Contractors are advised to refer to the full NIST and CIS documentation for further information about the controls, although this is purely for guidance – only the rules given in this document are mandatory.
The NIST Special Publication distinguishes the following security and privacy control families (this baseline only includes the relevant families):

ID	Family
AC	Access Control
AT	Awareness and Training
AU	Audit and Accountability

([5]) The CIS documents are licensed under a Creative Commons Attribution-ShareAlike 4.0 International License: http://creativecommons.org/licenses/by-sa/4.0/.

ID	Family
CA	Security Assessment and Authorisation
CM	Configuration Management
CP	Contingency Planning
IA	Identification and Authentication
IR	Incident Response
MA	Maintenance
MP	Media Protection
PE	Physical and Environmental Protection
PL	Planning
PM	Program Management
PS	Personnel Security
PT	Personally Identifiable Information Processing and Transparency
RA	Risk Assessment
SA	System and Services Acquisition
SC	System and Communications Protection
SI	System and Information Integrity
SR	Supply Chain Risk Management

In addition, the security baseline starts with a number of general rules that are based upon the EASA's internal security and HR policies and which are not covered by the NIST control framework.

6.1 BASELINE RULES FOR ALL SCENARIOS

The rules in section 6.1 are applicable to the contractor and, where specified, to the individual service provider. Rules that must be followed by the service provider are also specified in the individual service provider security commitmentin section 7 below.
These rules are applicable for all of the categories of service providers that are in scope of this security baseline (PPI, PPW, PXE and PXI) and for all contractors that provide these service providers. They apply to all working scenarios (including all locations, all types of end devices and all EASA systems and information accessed).

6.1.1 General rules

Ref	General rules
1	Any remote service delivery site for a service provider (contractor premises or home office) must be located in an EU Member State.
2	Service providers may also participate in missions outside the EU upon request from EASA. In this case, service providers in collaboration with the contracting authority must obtain mission security advice in advance as described in the Intranet and apply the recommended measures ([6]).

([6]) The measures for missions outside the EU depend on the circumstances of the mission and are out of scope of this document. Typically, they may include recommendations on working practices

Ref	General rules
3	The contractor must nominate a single point of contact (SPOC) for security issues relating to the contract and to ensure the communication between EASA's security teams and the relevant parties within the contractor.
4	Contractors and their staff must be aware of and comply with EASA's security rules relating to their activities, the level of confidentiality of the information that they handle, and any relevant handling instructions (notably for sensitive non-classified (SNC) information, see https://europa.eu/!db43PX).
5	Contractors and their staff must not take EASA equipment or non-public EASA information outside the EU unless this is explicitly authorised for a mission to a non-EU country (see rule 2 above).
6	Contractors must ensure that all service providers sign the applicable individual service provider security commitment (see section 7) and follow any specific policies or rules for acceptable use relating to the CISs used.
7	EASA information that is not publicly available must not be shared with any personnel without a need-to-know to fulfil their contracted tasks for the EASA.
8	EASA information that is not publicly available must not be stored or processed on any non-EASA devices or services.
9	The use of any public online tools that are not authorised for use by the EASA, such as instant messaging services or file storage/exchange platforms, is forbidden for handling, discussing or exchanging EASA information.
10	EASA equipment and services must only be used for the fulfilment of services contracted for the EASA. All EASA equipment and information must be returned upon completion of the contracted services.
11	Contractors and service providers should not permit seizure of EASA information or equipment by any non-EASA authorities or personnel, and must inform the EASA of any such attempt.
12	In line with the standard contractual obligations, any non-disclosure or secrecy obligations continue to be binding after the completion of the contracted services.
13	The rules in this security baseline must be applied to any subcontractors who are involved in the delivery of (supporting) services.
14	The specific controls listed in section 6 must be implemented as relevant, and their implementation must be documented. Any exceptions or compensating controls must be documented and reported during any verification of compliance.
15	The contractor must cooperate with the EASA or any third party appointed by the EASA for the verification of compliance with these rules.
16	The process for the verification of compliance with these rules may cover: I. the documentation of the contractor's implementation of the specific controls; II. relevant security certifications of the contractor; III. the results of external audits/assessments; and IV. on-site inspections by the EASA in the contractor's premises. The contractor must provide the relevant evidence and access for this process.

while on mission or measures such as the use of clean, dedicated IT equipment that is returned at the end of the mission.

6.1.2 Access Control

Ref	AC-2 Account Management
1	All user accounts in EASA CISs must be assigned to identified individuals. Shared accounts are not permitted unless an exception is authorised by the EASA system owner and accountability for each account is assigned to a specified individual.
2	Apply the EASA's procedures for requesting and reviewing access to EASA resources. All access requests must be documented, including the justification for access.
3	Where the administration of access management procedures for a EASA CIS is outsourced to the contractor, the EASA's internal rules on access management must be followed under the authority of the EASA system owner.
4	Notify EASA system owners when accounts are no longer required/users are terminated or transferred/system usage or need-to-know changes for an individual.

Ref	AC-5 Separation of Duties
1	Contractors and service providers must respect any segregation that is imposed by the CISs accessed.

6.1.3 Awareness and Training

Ref	AT-2 Literacy Training and Awareness
1	The contractor must provide and keep records of security awareness training to its personnel, covering fundamental and role-based security issues.
2	Service providers must also follow any security-related training required by the EASA, in particular the initial briefing on information security and acceptable use of EASA CISs and information that must be followed within three months of starting to work for the EASA.

6.1.4 Security Assessment and Authorisation

Ref	CA-2 Control Assessments
1	The security measures defined in this baseline must be assessed by the contractor or an independent assessor at least every three years. The results of this assessment must be made available to the contracting authority upon request.

Ref	CA-5 Plan of Action and Milestones
1	Develop a plan of action and milestones to document the planned remediation actions of the organisation to correct weaknesses or deficiencies noted during the assessment of the security measures, to be provided to the EASA upon request.

6.1.5 Identification and Authentication

Ref	IA-1 Policy and Procedures
1	The contractor must have formal recruitment processes to verify the service provider's identity, education and work experience, including a criminal records check or equivalent.

Ref	IA-5 Authenticator Management
1	Credentials for access to the EASA must only be issued via a formal procedure including verification of the user's identity as required by the system owner (in collaboration with the contractor where relevant).

6.1.6 Incident Response

Ref	IR-1 Policy and Procedures
1	The contractor must have a documented incident response procedure.
2	The contractor's single point of contact for security (see section 6.1.1, rule 3) must ensure effective communication between the contractor and the EASA regarding any relevant security incidents.
3	The contractor and service provider must report any relevant security incidents to the EASA's IT Service Desk without undue delay (within 48 hours), provide all relevant information and cooperate fully with any security investigations.
4	The contractor must ensure that any relevant evidence is preserved and made available to the EASA's security investigators, including the results of the root cause analysis and any subsequent forensic examination.
5	The EASA may instigate the compliance verification process following a security incident.

6.1.7 Media Protection

Ref	MP-2 Media Access
1	The use of removable media for EASA information must be generally discouraged and restricted as much as possible.
2	EASA information must only be stored on removable media provided by the EASA. These media must not be used for non-EASA information.
3	Any EASA information on removable media at the level of sensitive non-classified (SNC) or above must be encrypted.
4	Removable media containing EASA information must be protected against unauthorised disclosure, loss and theft.
5	Any non-public EASA information must be securely deleted from removable media when no longer needed (e.g. by performing a full format), or at latest at the termination of the contract.
6	Users must not connect media from unknown or suspicious sources to the IT equipment of the EASA or of the contractor (e.g. media that are found unattended or received from unknown people).

6.1.8 Personnel Security

Ref	PS-2	Position Risk Designation
1	The contracting authority in the EASA must inform the contractor which roles are considered to be sensitive, and therefore what sort of security verification is required. The options are: i. Standard; ii. Highly sensitive (tasks requiring a security clearance).	

Ref	PS-3	Personnel Screening
1	The contractor must provide the appropriate level of screening in line with the sensitivity of the tasks to be performed and inform the EASA of the results. The options are: i. Standard: the contractor must have formal recruitment processes to verify the service provider's identity, education and work experience, including a criminal record check or equivalent. The EASA performs a background screening where available. ii. Highly sensitive: additionally, the contractor must apply for a national security clearance from a Member State or a recognised third country for the service provider as soon as possible. The EASA can only recognise security clearances for non-EU nationals of countries with which the EU has a Security of Information agreement or from a Member State that can clear non-EU nationals on their territory.	

Ref	PS-4	Personnel Termination
1	The EASA must be informed of the termination of a service provider's contract to ensure that all user IDs are removed, and any EASA assets are returned (EASA information, laptop, hardware tokens, IT equipment, access badges etc.).	
2	The service provider must be reminded of the continuing obligation to respect the confidentiality of EASA information.	

Ref	PS-5	Personnel Transfer
1	When a service provider is transferred to a different role for the EASA, the contractor must inform the EASA to ensure that all access rights are modified accordingly. Transfer within the contractor to a non-EASA role requires the same procedure as termination.	

7 INDIVIDUAL SERVICE PROVIDER SECURITY COMMITMENT

This commitment contains rules to be followed by all service providers having access to EASA information or IT resources. All PPI, PPW, PXE and PXI service providers must sign this commitment to indicate their agreement. The signed commitments must be collected by the contractor for any service provider and submitted to the contracting authority at the start of the contract.

General Principles

1. The EASA provides information communication and technology (ICT) services for EASA business and the related security rules and handling instructions. The use of EASA information or IT resources for personal use or other business purposes is forbidden.
2. Service providers must give their assent to the appropriate level of screening during the recruitment process.
3. Service providers must be aware of the level of confidentiality of the information that they handle.
4. EASA information that is not publicly available must not be stored or processed on any non-EASA devices or services except as specified in the service contract, and it must not be shared with any personnel without a need-to-know to fulfil their contracted tasks for the EASA.
5. Paperless working is recommended where possible and particularly while performing remote service delivery. Printed documents containing sensitive information must be locked away when not in use.
6. Service providers must not take EASA equipment or non-public EASA information outside the EU unless this is explicitly authorised for a mission to a non-EU country.
7. Service providers must only use accounts that have been assigned to them. They must not share their accounts with other individuals or use shared accounts unless an exception is authorised by the EASA system owner and accountability for each account is assigned to a specified individual.
8. Authentication mechanisms must be protected from use by unauthorised persons at all times.
9. Service providers must use different passwords for accessing EASA CISs from any other passwords.
10. Service providers remain fully responsible for all equipment supplied by the EASA and for the actions taken in their name while using EASA equipment or services. Service providers must inform the EASA without undue delay (within 48 hours) via the IT Service Desk of any suspected or confirmed security incident or weakness. They must not test or exploit any security weaknesses, or seek to circumvent the security measures put in place by the EASA.
11. Service providers must follow any security-related training required by the EASA, in particular the initial briefing on information security and acceptable use of EASA CISs and information that must be followed within three months of starting to work for the EASA.

End user devices (workstations, laptops or other personal computing devices)

12. All EASA devices must be protected from access or theft by unauthorised persons at all times including during transport.
13. In shared offices or homes, working in common areas is discouraged and end user devices used for EASA business must not be left unlocked or unattended.
14. Software from non-EASA sources must not be installed or used on EASA IT equipment. Service providers must not change the security configuration of the operating system and any other installed software.
15. EASA devices and contractor devices may only connect to authorised networks for the purpose of connecting to the EASA remote access services. Authorised networks include:

- the EASA's internal network (for EASA devices) or guest wi-fi (for contractor devices) when on EASA premises;
- the contractor's internal network;
- the service provider's home network or their personal mobile telephone hotspot while performing remote service delivery;
- any authorised network service contracted by the EASA.

16. Service providers must not use any unauthorised or public online services for EASA purposes (e.g. in the event that the EASA's remote access solutions are unavailable).
17. Security measures installed on end user devices provided by the EASA, including anti-malware software and firewalls, must not be disabled or their configuration changed.
18. Service providers must not allow unauthorised people to use the EASA's equipment, information or services, including friends and family members.
19. Service providers must be attentive to signs of unauthorised use of endpoint devices. They must promptly report any suspected security breaches such as unrecognised access attempts via the appropriate channels.
20. Service providers must preserve any logs or other evidence of security incidents on any relevant IT equipment.
21. Service providers should not permit seizure of EASA information or equipment by any non-EASA authorities or personnel, and must inform the EASA of any such attempt.

EASA communication and information systems (CISs)

22. The EASA's CISs must only be used for the provision of the services described in the contract and in line with the EASA's policies and any rules or guidelines on acceptable use issued by the system owner.
23. Service providers must not access CISs for which they have not been explicitly granted authorisation.
24. Privileged access rights such as system administration must be used with extreme care. Service providers with administrative privileges must use a dedicated account for administrative tasks, and administrative accounts must not be used for any other activities.
25. Service provider must be vigilant of attacks such as phishing or scams.
26. Service providers using EASA devices must only encrypt sensitive non-classified emails with an authorised encryption tool.

Use of removable media and online services

27. The use of removable media for EASA information is strongly discouraged. All files must be securely deleted as soon as they are no longer needed.
28. EASA information must only be stored on removable media provided by the EASA. These media must not be used for non-EASA information.
29. Users must not connect media from unknown or suspicious sources to equipment that is used to access EASA services.
30. Removable media containing EASA information must be protected against unauthorised disclosure, loss and theft. Security incidents involving removable media containing EASA information must be reported to the EASA via the IT Service Desk.
31. Sensitive non-classified information must be encrypted when stored on removable media.

32. Online services that are not provided or authorised by the EASA must not be used for communicating (videoconferencing/teleconferencing), storing or transferring EASA information that is not publicly available.

Remote service delivery

33. Remote service delivery must only be performed from contractor premises or the service provider's home office which must be located in an EU Member State and may be his/her own home or a similar location such as the residence of a relative or partner where the relevant security measures can be applied. Remote service delivery is not permitted from public spaces such as hotel lobbies, restaurants, airports, train stations or social clubs.
34. Service providers must be aware of the physical security of the environment where they are using remote access and take appropriate steps to reduce risks such as eavesdropping, unauthorised observation of their activities, and loss or theft of their equipment or credentials.
35. Home offices must be protected from intrusion, e.g. with locked doors on the premises. In shared homes, working in common areas is discouraged and equipment must not be left unlocked or unattended.
36. When using home networks for remote service delivery, the following measures must be in place:
    - Home networks must not be shared with unknown third parties;
    - Wireless networks must be encrypted and protected with a strong password;
    - Passwords used to access home networks, such as for wireless networks, must be changed from the default passwords;
    - EASA devices must not be connected to other home computing devices;
    - EASA devices must not be used to connect to the Internet except through the EASA's authorised networks.

Logging and monitoring

37. The service provider must accept that the supplied equipment will be subject to regular checks by the EASA. These may take the form of physical verification, user surveys and log consultation.
38. The service provider consents to the EASA logging and monitoring activities on the EASA's end user devices and CISs for security purposes. All such logs will be handled in accordance with the relevant privacy statements.

Termination

39. At the end of the contracted services, all EASA IT resources including end user devices, physical authentication mechanisms and information must be returned to the EASA.
40. The service provider must cooperate with a request from the EASA for a handover process &/or exit interview.
41. All non-disclosure or secrecy obligations continue to be binding after the completion of the contracted services.

Confirmation

I hereby confirm that I have read, understood and will abide by the rules in this individual service provider security commitment.

Contractor company:	
Service provider (last name, first name):	
Signature:	
Date:	